



Πανεπιστήμιο Πειραιώς
Σχολή Τεχνολογιών Πληροφορικής και Τηλεπικοινωνιών
Τμήμα Ψηφιακών Συστημάτων

Επίπεδο: Μεταπτυχιακό Πρόγραμμα Σπουδών

Ασφάλεια Δικτύων

Case 7

Επιβλέπον Καθηγητής: Καθ. Χρήστος Ξενάκης

Καλαϊτζίδης Ιωάννης

ioannis_kalaitzidis@ssl-unipi.gr

Πειραιάς
24/12/2025

Περίληψη

Υλοποίηση αρχιτεκτονικής ασφαλείας «Defense-in-Depth» σε περιβάλλον Ubuntu Server, με συνδυασμένη χρήση του iptables (Network Firewall) για έλεγχο θυρών και του ModSecurity (WAF) για προστασία διαδικτυακών εφαρμογών. Εφαρμογή αυστηρής πολιτικής ασφαλείας με αποκλειστική επιτρεπτή πρόσβαση σε SSH, HTTP/S και στη θύρα 9001, και καθολική απόρριψη (DROP) κάθε άλλης κίνησης. Επιβεβαίωση της αποτελεσματικότητας μέσω ελέγχων από Kali Linux, με επιτυχή αποκλεισμό μη εξουσιοδοτημένων συνδέσεων από το firewall και αποτροπή επιθέσεων SQL Injection από το WAF.

Abstract

Implementation of a «Defense-in-Depth» security architecture on an Ubuntu Server, utilizing iptables (Network Firewall) for port filtering and ModSecurity (WAF) for web application protection. Enforcement of a strict security policy permitting only SSH, HTTP/S, and port 9001 traffic, while systematically dropping all other incoming packets. Verification of system integrity via penetration testing from Kali Linux, demonstrating the effective blocking of unauthorized access by the firewall and the prevention of SQL Injection attacks by the WAF.

Περιεχόμενα

Εισαγωγή.....	1
Πρακτικό κομμάτι εργασίας.....	2
Βιβλιογραφία.....	10

Εισαγωγή

Στο πλαίσιο της παρούσας εργαστηριακής άσκησης, πραγματοποιήθηκε η υλοποίηση και παραμετροποίηση μιας αρχιτεκτονικής ασφαλείας βασισμένης στο μοντέλο «Άμυνας σε Βάθος» (Defense-in-Depth). Για τις ανάγκες του σεναρίου, χρησιμοποιήθηκαν δύο εικονικές μηχανές (Virtual Machines) με διακριτούς ρόλους, προσομοιώνοντας ένα περιβάλλον επίθεσης και άμυνας.

Το πρώτο σύστημα (Ubuntu) λειτουργεί υβριδικά ως εξυπηρετητής (Server) και κόμβος ασφαλείας, εφαρμόζοντας μέτρα προστασίας σε επίπεδο host (Host-based Security). Ως Server, φιλοξενεί τις απαραίτητες υπηρεσίες, συγκεκριμένα τον Apache Web Server για τη διαχείριση κίνησης HTTP/HTTPS, καθώς και μια προσαρμοσμένη υπηρεσία στη θύρα 9001. Σε αντίθεση με τις υποδομές που βασίζονται αποκλειστικά σε περιμετρικά firewalls, η παρούσα υλοποίηση ενεργοποιεί την ασφάλεια απευθείας στον Server μέσω δύο επιπέδων ελέγχου: αφενός του iptables (Network Firewall) για το φιλτράρισμα πακέτων δικτύου και αφετέρου του ModSecurity (Web Application Firewall-WAF) για την ανίχνευση κακόβουλων δεδομένων εντός των εφαρμογών.

Το δεύτερο σύστημα (Kali Linux) αναλαμβάνει τον ρόλο του πελάτη/επιτιθέμενου (Client/Attacker). Μέσω αυτού διενεργούνται έλεγχοι συνδεσιμότητας και προσομοιώσεις επιθέσεων, με στόχο την επαλήθευση της ακεραιότητας και της αποτελεσματικότητας των κανόνων φιλτραρίσματος που εφαρμόστηκαν στο Ubuntu VM.

Πρακτικό κομμάτι εργασίας

```
kalaitzon@ubuntudesktop1:~$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: ens32: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 00:0c:29:f5:51:1f brd ff:ff:ff:ff:ff:ff
    altname enp2s0
    inet 192.168.137.129/24 brd 192.168.137.255 scope global dynamic noprefixroute ens32
        valid_lft 1445sec preferred_lft 1445sec
    inet6 fe80::20c:29ff:fef5:511f/64 scope link
        valid_lft forever preferred_lft forever
```

Αρχικά πρέπει να βρούμε την ip του Ubuntu με την εντολή **ip a**. Η ip είναι: **192.168.137.129**

```
kalaitzon@ubuntudesktop1:~$ apt update && sudo apt install apache2 libapache2-mod-security2 netcat-openbsd -y
Reading package lists... Done
E: Could not open lock file /var/lib/apt/lists/lock - open (13: Permission denied)
E: Unable to lock directory /var/lib/apt/lists/
W: Problem unlinking the file /var/cache/apt/pkgcache.bin - RemoveCaches (13: Permission denied)
W: Problem unlinking the file /var/cache/apt/srcpkgcache.bin - RemoveCaches (13: Permission denied)
kalaitzon@ubuntudesktop1:~$
```

Στη συνέχεια θα κατεβάσουμε και θα ενημερώσουμε τις παρακάτω εφαρμογές:

- **Apache2:** Είναι ο πιο δημοφιλής web server και απαιτείται για να υπάρχει λειτουργία HTTP/HTTPS. Είναι ο server με τον οποίο θα δημιουργήσουμε την ιστοσελίδα που θα συνδεθεί ο client (Kali Linux).
- **Libapache2-mod-security2:** Είναι το web application firewall (WAF). Προσφέρει ασφάλεια στο server από τις web επιθέσεις. Ουσιαστικά θα μπει ανάμεσα στον Apache και θα ελέγχει τα δεδομένα για να μπλοκάρει επιθέσεις όπως SQL injections κλπ.
- **Netcat-openbsd:** Είναι το εργαλείο που θα χρησιμοποιήσουμε για διαβάζουμε και να γράφουμε δεδομένα σε συνδέσεις δικτύου. Λόγω ότι στην εκφώνηση της άσκησης έχει βασική προϋπόθεση το να είναι ανοικτή η θύρα 9001, θα χρησιμοποιήσουμε το netcat για να ανοίξουμε αυτή την πόρτα.

Στο screenshot παρατηρούμε ότι αυτή η εντολή που εγκαθιστά και ενημερώνει τις παραπάνω εφαρμογές δε δουλεύει διότι δεν είχαμε διαχειριστικά δικαιώματα. Με την προσθήκη του «**sudo**» μπροστά από την υπόλοιπη εντολή, λύνεται το πρόβλημα.

```
kalaitzon@ubuntudesktop1:~$ sudo service apache2 start
kalaitzon@ubuntudesktop1:~$ sudo service apache2 status
● apache2.service - The Apache HTTP Server
   Loaded: loaded (/usr/lib/systemd/system/apache2.service; enabled; preset: enabled)
   Active: active (running) since Wed 2025-12-24 00:55:14 EET; 1min 49s ago
     Docs: https://httpd.apache.org/docs/2.4/
   Process: 6385 ExecStart=/usr/sbin/apachectl start (code=exited, status=0/SUCCESS)
  Main PID: 6389 (apache2)
    Tasks: 55 (limit: 9374)
   Memory: 29.0M (peak: 29.6M)
      CPU: 499ms
   CGroup: /system.slice/apache2.service
           └─6389 /usr/sbin/apache2 -k start
             └─6394 /usr/sbin/apache2 -k start
               └─6396 /usr/sbin/apache2 -k start

Dec 24 00:55:13 ubuntudesktop1.kalaitzon systemd[1]: Starting apache2.service - The Apache HTTP Server...
Dec 24 00:55:14 ubuntudesktop1.kalaitzon systemd[1]: Started apache2.service - The Apache HTTP Server.
kalaitzon@ubuntudesktop1:~$
```

Στη συνέχεια ενεργοποιούμε τον web server με την εντολή «**sudo service apache2 start**» και για να ελέγξουμε αν δουλεύει ο apache server, χρησιμοποιούμε την εντολή «**sudo service apache2 status**». Το αποτέλεσμα, όπως φαίνεται στο screenshot, δείχνει ότι όλα πήγαν καλά και ότι ο server είναι ανοικτός και περιμένει συνδέσεις HTTP/HTTPS.

```
kalaitzon@ubuntudesktop1:~$ nc -l -p 9001
```

Εδώ θα χρησιμοποιήσουμε το εργαλείο netcat και με την εντολή `nc -l -p 9001` θα δημιουργήσουμε μία υπηρεσία διαδικτύου. Με την παράμετρο «-l» λέμε στο σύστημα να περιμένει σύνδεση (listen) αντί να συνδεθεί κάποιου άλλου. Με την παράμετρο «-p» δηλώνουμε ποια θύρα να ανοίξει, δηλαδή την 9001. Χωρίς την εντολή αυτή, ακόμα και αν ρυθμίζαμε το firewall να επιτρέψει την 9001, η πόρτα θα ήταν κλειστή γιατί δε θα υπήρχε πρόγραμμα να την χρησιμοποιεί. Μόλις τρέξουμε την εντολή, ο κέρσορας θα αναβοσβήνει και σημαίνει ότι η εντολή τρέχει κανονικά και ο server είναι σε κατάσταση αναμονής. Θα αφήσουμε αυτό το τερματικό ανοικτό για να συνεχίζει να «ακούει» η πόρτα και θα ανοίξουμε ένα νέο τερματικό.

```

kalaitzon@ubuntudesktop1:~$ sudo iptables -F
[sudo] password for kalaitzon:
kalaitzon@ubuntudesktop1:~$ sudo iptables -A INPUT -p tcp --dport 22 -j ACCEPT
kalaitzon@ubuntudesktop1:~$ sudo iptables -A INPUT -p tcp --dport 80 -j ACCEPT
sudo: iptab: command not found
es: command not found
kalaitzon@ubuntudesktop1:~$ sudo iptables -A INPUT -p tcp --dport 80 -j ACCEPT
kalaitzon@ubuntudesktop1:~$ sudo iptables -A INPUT -p tcp --dport 443 -j ACCEPT
kalaitzon@ubuntudesktop1:~$ sudo iptables -A INPUT -p tcp --dport 9001 -j ACCEPT
kalaitzon@ubuntudesktop1:~$ sudo iptables -A INPUT -i lo -j ACCEPT
sudo: iptab: command not found
es: command not found
kalaitzon@ubuntudesktop1:~$ sudo iptables -A INPUT -m conntrack --ctstate ESTABLISHED,RELATED -j ACCEPT
kalaitzon@ubuntudesktop1:~$ sudo iptables -P INPUT DROP
kalaitzon@ubuntudesktop1:~$ sudo iptables -P FORWARD DROP
kalaitzon@ubuntudesktop1:~$ sudo iptables -L -v -n
Chain INPUT (policy DROP 0 packets, 0 bytes)
 pkts bytes target     prot opt in     out     source                 destination
    0     0 ACCEPT     6     -- *     *       0.0.0.0/0             0.0.0.0/0           tcp dpt:22
    0     0 ACCEPT     6     -- *     *       0.0.0.0/0             0.0.0.0/0           tcp dpt:80
    0     0 ACCEPT     6     -- *     *       0.0.0.0/0             0.0.0.0/0           tcp dpt:443
    0     0 ACCEPT     6     -- *     *       0.0.0.0/0             0.0.0.0/0           tcp dpt:9001
    0     0 ACCEPT     0     -- lo    *       0.0.0.0/0             0.0.0.0/0
    0     0 ACCEPT     0     -- *     *       0.0.0.0/0             0.0.0.0/0           ctstate RELATED,ESTABLISHED

Chain FORWARD (policy DROP 0 packets, 0 bytes)
 pkts bytes target     prot opt in     out     source                 destination

Chain OUTPUT (policy ACCEPT 0 packets, 0 bytes)
 pkts bytes target     prot opt in     out     source                 destination
kalaitzon@ubuntudesktop1:~$ S

```

Στη συνέχεια θα δημιουργήσουμε τους κανόνες του firewall μέσω του εργαλείου iptables. Ουσιαστικά με το τείχος προστασίας θα καθορίσουμε ποιος επιτρέπεται να μπει και ποιος όχι.

Με την εντολή «**sudo iptables -F**» διαγράφουμε (-F) όλους τους προηγούμενους κανόνες. Αυτό το κάνουμε για να έχουμε μία «καθαρή» βάση για να μη δημιουργηθεί κάποιο πρόβλημα από τους προϋπάρχοντες.

Με την εντολή «**sudo iptables -A INPUT -p tcp --dport 22 -j ACCEPT**», προσθέτουμε έναν κανόνα για το πρωτόκολλο TCP στην πόρτα 22, με εντολή να γίνει αποδεκτή (ACCEPT). Ανοίγουμε την πόρτα για το SSH ώστε να είναι εφικτή η σύνδεση απομακρυσμένα στον server.

Με την εντολή «**sudo iptables -A INPUT -p tcp --dport 80 -j ACCEPT**» και την εντολή «**sudo iptables -A INPUT -p tcp --dport 443 -j ACCEPT**» επιτρέπουμε την κίνηση στις πόρτες 80 και 443. Ουσιαστικά ανοίγουμε την πρόσβαση για τον web server (HTTP/HTTPS).

Με την εντολή «**sudo iptables -A INPUT -p tcp --dport 9001 -j ACCEPT**» επιτρέπουμε την κίνηση στην πόρτα 9001. Αυτό το κάναμε διότι αποτελεί συγκεκριμένη απαίτηση του Use Case 7, προκειμένου να επιτραπεί η πρόσβαση στην προσαρμοσμένη υπηρεσία που φιλοξενεί ο server για να εξυπηρετεί τον client.

Με την εντολή «**sudo iptables -A INPUT -i lo -j ACCEPT**» επιτρέπουμε την κίνηση στο loopback interface (lo). Με άλλα λόγια επιτρέπουμε στον server να μιλάει στον εαυτό του. Αυτό το κάνουμε διότι πολλές υπηρεσίες του συστήματος επικοινωνούν μεταξύ τους μέσω του localhost (127.0.0.1) και η παρεμπόδιση αυτής της κίνησης θα προκαλούσε δυσλειτουργίες στο λειτουργικό σύστημα.

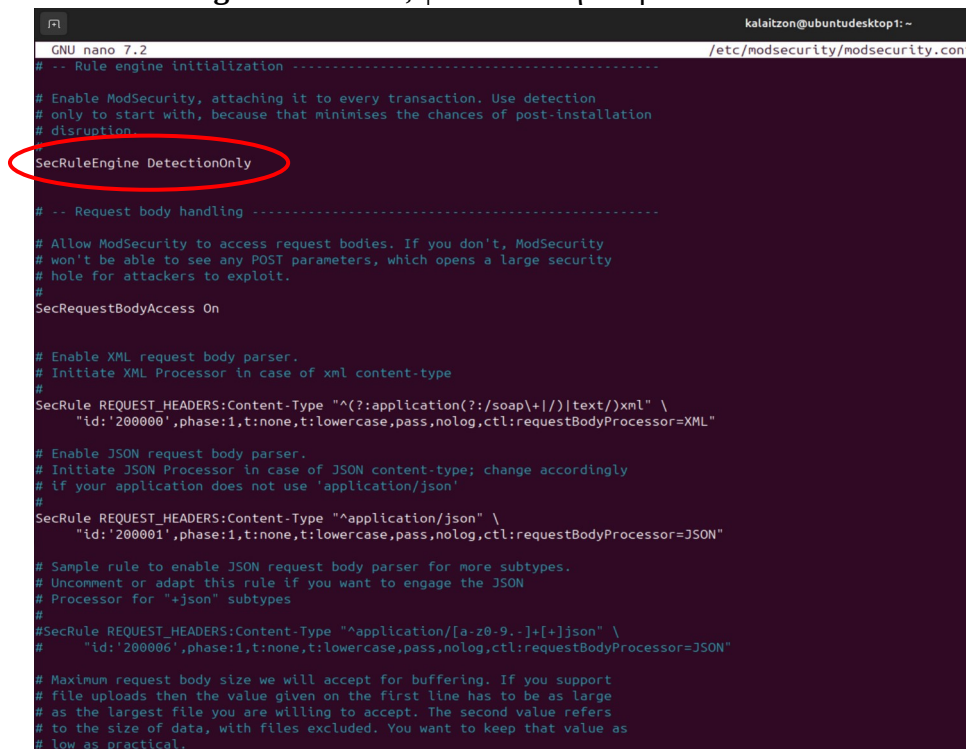
Με την εντολή «**sudo iptables -A INPUT -m conntrack --ctstate ESTABLISHED,RELATED -j ACCEPT**» επιτρέπουμε πακέτα που ανήκουν σε ήδη ανοικτές συνδέσεις. Ουσιαστικά εξασφαλίζουμε ότι αν ο server ζητήσει κάτι από το internet, η απάντηση θα μπορέσει να επιστρέψει. Χωρίς αυτό, το firewall θα έκοβε τις απαντήσεις στα δικά του αιτήματα.

Με την εντολή «**sudo iptables -P INPUT DROP**» και την εντολή «**sudo iptables -P FORWARD DROP**» αλλάζουμε την πολιτική (-P) σε DROP. Αυτό είναι το πιο σημαντικό κομμάτι ανάμεσα στις εντολές που γράψαμε καθώς αν ένα πακέτο δεν ταιριάζει με κανέναν από τους παραπάνω κανόνες (22, 80, 443, 9001), τότε να το αγνοεί. Δηλαδή υλοποιούμε εδώ μία κατάσταση στην οποία όλες οι θύρες είναι κλειστές πλην των αναφερόμενων.

Τέλος, με την εντολή «**sudo iptables -L -v -n**» εμφανίσαμε την λίστα με τους ενεργούς κανόνες για επιβεβαίωση. Η λίστα επιβεβαιώνει τα όσα κάναμε παραπάνω (οι πόρτες που θέλουμε είναι ACCEPT και η πολιτική γενικά είναι DROP).

```
kalaitzon@ubuntudesktop1:~$ sudo cp /etc/modsecurity/modsecurity.conf-recommended /etc/modsecurity/modsecurity.conf
kalaitzon@ubuntudesktop1:~$ sudo nano /etc/modsecurity/modsecurity.conf
kalaitzon@ubuntudesktop1:~$ sudo service apache2 restart
```

Στη συνέχεια με την εντολή «**sudo cp /etc/modsecurity/modsecurity.conf-recommended /etc/modsecurity/modsecurity.conf**» αντιγράφουμε το αρχείο με τις προτεινόμενες ρυθμίσεις και δημιουργούμε ένα κύριο αρχείο ρυθμίσεων (modsecurity.conf). Αυτό το κάνουμε διότι το modsecurity δεν έχει ενεργό αρχείο ρυθμίσεων. Πρέπει να δημιουργήσουμε αυτό το αρχείο για να αρχίσει να λειτουργεί σωστά. Στη συνέχεια με την εντολή «**sudo nano /etc/modsecurity/modsecurity.conf**» ανοίγουμε το συγκεκριμένο αρχείο και αλλάζουμε τη ρύθμιση από «**SecRuleEngine DetectionOnly**» σε «**SecRuleEngine On**» όπως φαίνεται στην παρακάτω εικόνα.



```
GNU nano 7.2 /etc/modsecurity/modsecurity.conf
# -- Rule engine initialization -----
# Enable ModSecurity, attaching it to every transaction. Use detection
# only to start with, because that minimises the chances of post-installation
# disruption.
SecRuleEngine DetectionOnly

# -- Request body handling -----
# Allow ModSecurity to access request bodies. If you don't, ModSecurity
# won't be able to see any POST parameters, which opens a large security
# hole for attackers to exploit.
SecRequestBodyAccess On

# Enable XML request body parser.
# Initiate XML Processor in case of xml content-type
#
SecRule REQUEST_HEADERS:Content-Type "^(?:application(?:/soap\+|/)|text/)xml" \
    "id:'200000',phase:1,t:none,t:lowercase,pass,nolog,ctl:requestBodyProcessor=XML"

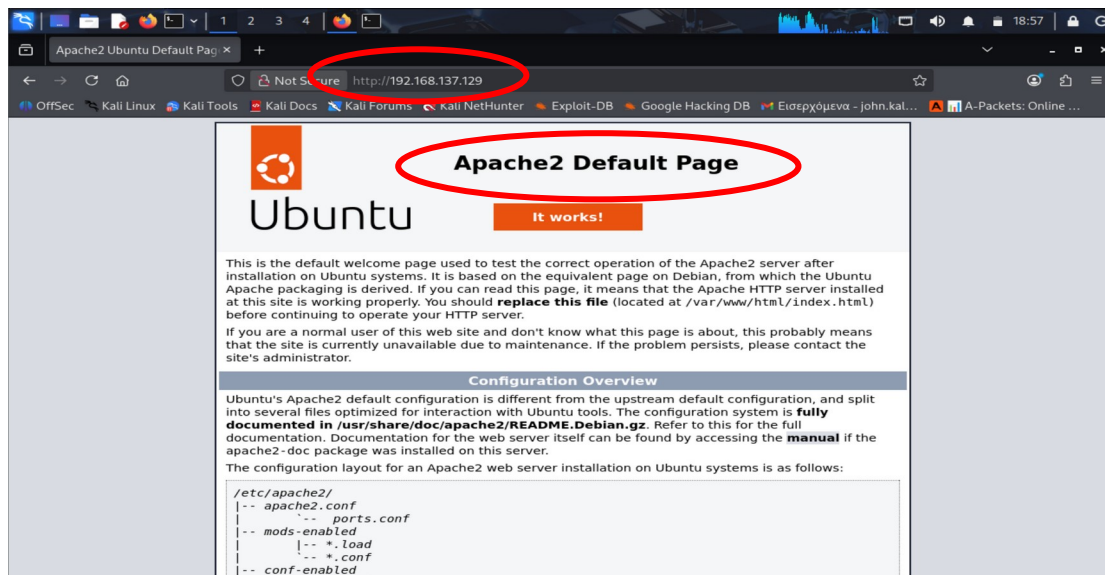
# Enable JSON request body parser.
# Initiate JSON Processor in case of JSON content-type; change accordingly
# if your application does not use 'application/json'
#
SecRule REQUEST_HEADERS:Content-Type "application/json" \
    "id:'200001',phase:1,t:none,t:lowercase,pass,nolog,ctl:requestBodyProcessor=JSON"

# Sample rule to enable JSON request body parser for more subtypes.
# Uncomment or adapt this rule if you want to engage the JSON
# Processor for "+json" subtypes
#
SecRule REQUEST_HEADERS:Content-Type "application/[a-z0-9.-]+[+json]" \
    "id:'200006',phase:1,t:none,t:lowercase,pass,nolog,ctl:requestBodyProcessor=JSON"

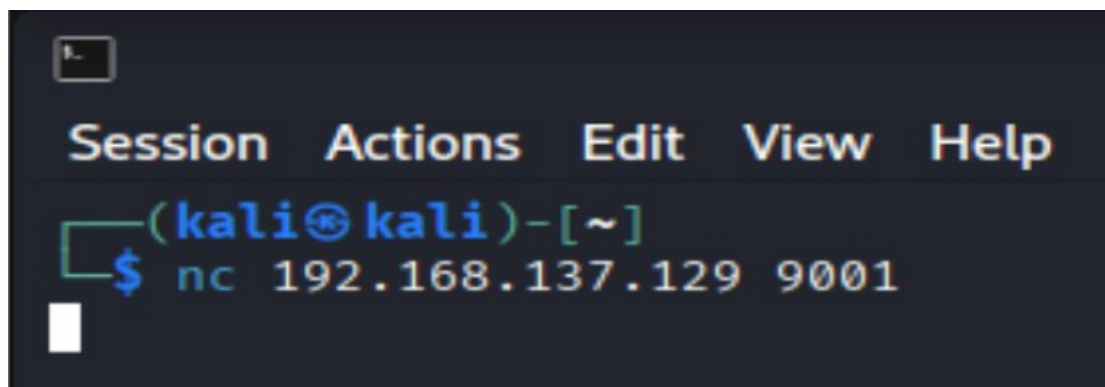
# Maximum request body size we will accept for buffering. If you support
# file uploads then the value given on the first line has to be as large
# as the largest file you are willing to accept. The second value refers
# to the size of data, with files excluded. You want to keep that value as
# low as practical.
```

Αυτό ήταν το τελευταίο βήμα ώστε το ModSecurity να μπλοκάρει τις επιθέσεις. Τέλος με την εντολή «**sudo service apache2 restart**» επανεκκινούμε τον web server για να εφαρμοστούν όλες οι αλλαγές που κάναμε στο αρχείο των ρυθμίσεων και να τις διαβάσει το σύστημα ώστε να ενεργοποιηθεί το WAF.

Τώρα θα μεταβούμε στον client (Kali Linux) και θα χρησιμοποιήσουμε την ip του Ubuntu (server) ώστε να ελέγξουμε την θύρα 80. Αυτό θα το κάνουμε γράφοντας την ip στον browser του client.



Εφόσον μας εμφανίζει αυτή τη σελίδα, σημαίνει ότι όλα λειτουργούν όπως πρέπει. Στη συνέχεια θα ελέγξουμε την θύρα 9001 με το εργαλείο Netcat. Θα ανοίξουμε ένα τερματικό στο Kali Linux και θα γράψουμε την εντολή «**nc 192.168.137.129 9001**». Παρατηρούμε ότι η σύνδεση είναι πετυχημένη εφόσον ο κέρσορας αναβοσβήνει.



Για να το επιβεβαιώσουμε θα γράψουμε ακριβώς από κάτω το μήνυμα «**HELLO**» και θα πατήσουμε Enter. Θα επιστρέψουμε προσωρινά στο Ubuntu και θα πάμε στο

terminal

που

είχαμε

αφήσει

ανοικτό.

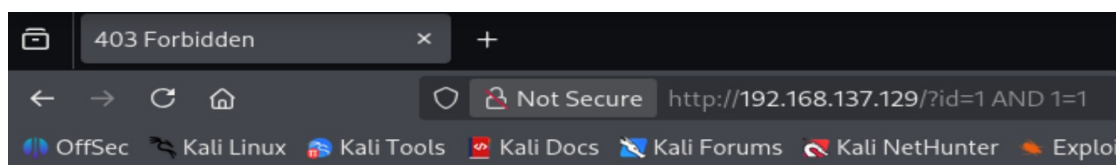
```
kalaitzon@ubuntu desktop1: ~  
Setting up libapache2-mod-security2 (2.9.7-1build3) ...  
apache2_invoke: Enable module security2  
Processing triggers for libc-bin (2.39-0ubuntu8.6) ...  
Processing triggers for ufw (0.36.2-6) ...  
Processing triggers for man-db (2.12.0-4build2) ...  
kalaitzon@ubuntu desktop1:~$ sudo service apache2 start  
kalaitzon@ubuntu desktop1:~$ sudo service apache2 status  
● apache2.service - The Apache HTTP Server  
   Loaded: loaded (/usr/lib/systemd/system/apache2.service; enabled; preset: enabled)  
   Active: active (running) since Wed 2025-12-24 00:55:14 EET; 1min 49s ago  
     Docs: https://httpd.apache.org/docs/2.4/  
   Process: 6385 ExecStart=/usr/sbin/apachectl start (code=exited, status=0/SUCCESS)  
    Main PID: 6389 (apache2)  
       Tasks: 55 (limit: 9374)  
    Memory: 29.0M (peak: 29.6M)  
         CPU: 499ms  
    CGroup: /system.slice/apache2.service  
            └─6389 /usr/sbin/apache2 -k start  
              └─6394 /usr/sbin/apache2 -k start  
                └─6396 /usr/sbin/apache2 -k start  
  
Dec 24 00:55:13 ubuntu desktop1.kalaitzon systemd[1]: Starting apache2.service - The Apache HTTP Server...  
Dec 24 00:55:14 ubuntu desktop1.kalaitzon systemd[1]: Started apache2.service - The Apache HTTP Server.  
kalaitzon@ubuntu desktop1:~$ q  
Command 'q' not found, but can be installed with:  
sudo snap install q # version 1.6.3-1, or  
sudo apt install python3-q-text-as-data # version 3.1.6-3  
See 'snap info q' for additional versions.  
kalaitzon@ubuntu desktop1:~$ nc -l -p 9001  
HELLO
```

Παρατηρούμε ότι το μήνυμα «**HELLO**» εμφανίστηκε και εδώ. Αυτό είναι η απόδειξη ότι η επικοινωνία λειτουργεί. Με άλλα λόγια ο client κατάφερε να συνδεθεί επιτυχώς στην πόρτα 9001 του Ubuntu (server). Άρα ο κανόνας iptables που φτιάξαμε προηγουμένως λειτουργεί σωστά. Αν το firewall ήταν λάθος ρυθμισμένο, το μήνυμα αυτό δε θα έφτανε ποτέ και δε θα εμφανιζόταν στο terminal του server.

```
(kali@kali)-[~]  
$ nmap -p 8080 192.168.137.129  
Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-23 19:01 EST  
Nmap scan report for 192.168.137.129  
Host is up (0.0018s latency).  
  
PORT      STATE      SERVICE  
8080/tcp  filtered  http-proxy  
MAC Address: 00:0C:29:F5:51:1F (VMware)  
  
Nmap done: 1 IP address (1 host up) scanned in 0.59 seconds  
  
(kali@kali)-[~]  
$
```

Τέλος με την εντολή «**nmap -p 8080 192.168.137.129**» ελέγχουμε την θύρα 8080 στο Ubuntu από το Kali Linux με το εργαλείο Nmap. Το αποτέλεσμα όπως παρατηρούμε είναι ότι το firewall έκοψε (DROP) και δεν έστειλε καμία απάντηση

πίσω. Άρα το iptables στο Ubuntu, έκανε σωστά την δουλειά του.



Forbidden

You don't have permission to access this resource.

Apache/2.4.58 (Ubuntu) Server at 192.168.137.129 Port 80

Για επιβεβαίωση, προσθέσαμε στο URL του Ubuntu την παράμετρο «**?id=1 AND 1=1**» ως προσομοίωση επίθεσης SQL Injection στον web server. Όπως παρατηρούμε, ο web server επέστρεψε μήνυμα σφάλματος «**403 Forbidden**». Αντί να εμφανιστεί η κανονική σελίδα, το σύστημα αρνήθηκε να εξυπηρετήσει το αίτημα. Το αποτέλεσμα αυτό αποδεικνύει ότι το ModSecurity λειτουργεί σωστά ως Web Application Firewall (WAF). Ανίχνευσε το κακόβουλο μοτίβο (AND 1=1) μέσα στο HTTP αίτημα και το μπλόκαρε άμεσα, προστατεύοντας την εφαρμογή από την επίθεση, όπως απαιτείται από το σενάριο ασφαλείας.

Πολιτική Ασφαλείας για Home Office

Για τη διασφάλιση υψηλού επιπέδου ασφάλειας σε περιβάλλον οικιακής εργασίας (Home Office), προτείνεται η υιοθέτηση και εφαρμογή των ακόλουθων πρακτικών:

- **Σκλήρυνση Ρυθμίσεων Router (Router Hardening):** Η ασφάλεια του router ενισχύεται με:
 - ο την αντικατάσταση των προεπιλεγμένων κωδικών πρόσβασης με ισχυρούς και μοναδικούς,
 - ο την απενεργοποίηση της απομακρυσμένης διαχείρισης (Remote Management),
 - ο την απενεργοποίηση του πρωτοκόλλου UPnP, το οποίο μπορεί να δημιουργήσει μη ελεγχόμενα ανοίγματα θυρών.
- **Διαχείριση Συσκευών και Ενημερώσεων:** Είναι απαραίτητη η ενεργοποίηση αυτόματων ενημερώσεων ασφαλείας για το λειτουργικό σύστημα και τις εγκατεστημένες εφαρμογές. Παράλληλα, κάθε συσκευή εργασίας πρέπει να

διαθέτει λογισμικό προστασίας (Antivirus ή EDR) καθώς και ενεργό τοπικό firewall (host-based firewall), ώστε να μειώνεται η επιφάνεια επίθεσης.

- **Χρήση Εικονικού Ιδιωτικού Δικτύου (VPN):** Η πρόσβαση σε εταιρικούς πόρους και υπηρεσίες πρέπει να πραγματοποιείται αποκλειστικά μέσω VPN, το οποίο παρέχει κρυπτογραφημένη επικοινωνία. Η χρήση VPN διασφαλίζει τόσο την εμπιστευτικότητα όσο και την ακεραιότητα των δεδομένων που μεταφέρονται, προστατεύοντάς τα από επιθέσεις υποκλοπής ή παρακολούθησης της κίνησης (sniffing).
- **Τμηματοποίηση Οικιακού Δικτύου (Network Segmentation):** Το οικιακό δίκτυο θα πρέπει να διαχωρίζεται σε τουλάχιστον δύο διακριτές ζώνες, μέσω VLANs ή της λειτουργίας «Guest Network» του router. Οι συσκευές που χρησιμοποιούνται για επαγγελματικούς σκοπούς οφείλουν να λειτουργούν σε απομονωμένο δίκτυο, αποκομμένο από μη αξιόπιστες ή μη ελεγχόμενες συσκευές (π.χ. IoT συσκευές, συσκευές επισκεπτών ή κονσόλες παιχνιδιών). Με αυτόν τον τρόπο περιορίζεται σημαντικά η πιθανότητα πλευρικής μετακίνησης (lateral movement) σε περίπτωση παραβίασης κάποιας συσκευής.
- **Φυσική Ασφάλεια Χώρου Εργασίας:** Η φυσική προστασία των πληροφοριών εξασφαλίζεται με το αυτόματο ή χειροκίνητο κλείδωμα της οθόνης κατά την απομάκρυνση από τον χώρο εργασίας και την εφαρμογή πολιτικής «καθαρού γραφείου» (Clean Desk Policy), ώστε ευαίσθητα έγγραφα ή πληροφορίες να μην είναι προσβάσιμα σε τρίτους.

Βιβλιογραφία

- Acunetix. (n.d.). 10 Tips to Secure Your Apache Web Server. <https://www.acunetix.com/blog/articles/10-tips-secure-apache-installation/>
- Apache Software Foundation. (n.d.). Apache HTTP Server Version 2.4 Documentation. <https://httpd.apache.org/docs/2.4/>
- Apache Software Foundation. (n.d.). Security Tips for Apache Server. https://httpd.apache.org/docs/2.4/misc/security_tips.html
- Cloudflare. (n.d.). What is a WAF? | Web Application Firewall explained. <https://www.cloudflare.com/learning/ddos/glossary/web-application-firewall-waf/>
- Computerphile. (2016, May 11). SQL Injection Explained [Video file]. <https://www.youtube.com/watch?v=ciNHn38EyRc>
- DigitalOcean. (2023). Iptables Essentials: Common Firewall Rules and Commands. <https://www.digitalocean.com/community/tutorials/ufw-essentials-common-firewall-rules-and-commands>
- GeeksforGeeks. (2024). iptables command in Linux with Examples. <https://www.geeksforgeeks.org/linux-unix/iptables-command-in-linux-with-examples/>
- Hussein Nasser. (2020, September 20). Apache ModSecurity Tutorial [Video file]. <https://www.youtube.com/watch?v=MB7nQrlP5Yc>
- Linux Manual. (n.d.). Ncat - Netcat for the 21st Century. <https://man7.org/linux/man-pages/man1/ncat.1.html>
- Netfilter Project. (n.d.). iptables(8)-Linux man page. <https://linux.die.net/man/8/iptables>
- NetworkChuck. (2021, July 15). Linux Firewalls (iptables) for Beginners. <https://www.youtube.com/watch?v=v-z6LCcrutw>
- OWASP Foundation. (n.d.). OWASP ModSecurity Core Rule Set (CRS). <https://owasp.org/www-project-modsecurity-core-rule-set/>
- OWASP Foundation. (n.d.). SQL Injection. https://owasp.org/www-community/attacks/SQL_Injection

- Palo Alto Networks. (n.d.). What is a Web Application Firewall (WAF)?.
<https://www.paloaltonetworks.com/cyberpedia/what-is-a-web-application-firewall>
- SpiderLabs. (n.d.). ModSecurity Reference Manual.
<https://github.com/SpiderLabs/ModSecurity/wiki>
- TecMint. (2023). How to Install ModSecurity with Apache on Debian/Ubuntu.
<https://www.tecmint.com/install-modsecurity-apache-debian-ubuntu/>